



KENYA PRIVACY LAW REVIEW

PRACTICE NOTE NO.

005

JULY 2026

PRACTICE NOTE SERIES

PRIVACY BY DESIGN

Embedding data protection
into systems, products and
processes under the Data
Protection Act, 2019

AUTHOR



Muchangi Patrick
Advocate

Technology Law • Data Protection •
Artificial Intelligence • Cybersecurity



PUBLISHED BY

Kenya Privacy Law Review (KPLR)



JULY 2026



REFERENCE: KPLR/PN/005/2026

PRIVACY
BY DESIGNDATA
PROTECTION

ACCOUNTABILITY



SECURITY



GOVERNANCE

—> ADVANCING EXCELLENCE IN PRIVACY,
TECHNOLOGY & DIGITAL GOVERNANCE <—

KENYA PRIVACY LAW REVIEW

Practice Note Series

Practice Note No. 005

PRIVACY BY DESIGN

Embedding data protection into systems, products and processes under the Data Protection Act, 2019

Author

Muchangi Patrick

Advocate

Technology Law • Data Protection • Artificial Intelligence • Cybersecurity

Published by

Kenya Privacy Law Review (KPLR)

July 2026

Reference: KPLR/PN/005/2026

Advancing Excellence in Privacy, Technology & Digital Governance

Copyright © 2026 Muchangi Patrick. All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, transmitted, distributed, or adapted in any form or by any means, whether electronic, mechanical, photocopying, recording, or otherwise, without the prior written permission of the copyright holder, except for brief quotations used for purposes of review, commentary, research, teaching, or other uses permitted by applicable copyright law.

Publication Information

PRIVACY BY DESIGN

Embedding data protection into systems, products and processes under the Data Protection Act, 2019

Practice Note No. 005

Copyright

Copyright © 2026 **Muchangi Patrick**.

All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, transmitted, distributed, or adapted in any form or by any means, whether electronic, mechanical, photocopying, recording, or otherwise, without the prior written permission of the copyright holder, except for brief quotations used for purposes of criticism, review, research, teaching, or other uses permitted by applicable copyright law.

Published by

Kenya Privacy Law Review (KPLR)

An independent legal publication dedicated to privacy, technology law, artificial intelligence, cybersecurity, digital governance, and emerging technologies.

Author

Muchangi Patrick

Advocate

Technology Law • Data Protection • Artificial Intelligence • Cybersecurity

Recommended Citation

Muchangi Patrick, Privacy by Design: Embedding Data Protection into Systems, Products and Processes under the Data Protection Act, 2019, Kenya Privacy Law Review, Practice Note No. 005 (July 2026).

Disclaimer

This Practice Note is published for general informational and educational purposes only. It provides independent legal analysis of selected issues relating to technology law, privacy, cybersecurity, artificial intelligence, and digital governance. It does not constitute legal advice and should not be relied upon as a substitute for legal advice tailored to specific facts and circumstances.

While every reasonable effort has been made to ensure the accuracy of the information contained in this publication as at the date of publication, the law may change over time. Readers are encouraged to obtain independent legal advice before acting on any information contained herein.

The views expressed are those of the author and do not necessarily reflect those of any regulator, institution, employer, client, or professional body.

Publication Details

Edition	First Edition
Publication Date	July 2026
Version	1.0
Reference	KPLR/PN/004/2026

Using a small table like this gives the page a clean, reference-book feel.

Contact

Muchangi Patrick

Advocate

Email: consult@dataprivacyadvocates.co.ke

LinkedIn: www.linkedin.com/in/patrick-muchangi-507498216

Website: dataprivacyadvocates.co.ke

This publication is issued as **KPLR Practice Note No. 005** and bears the publication reference **KPLR/PN/005/2026**, which serves as its official identifier for citation and reference purposes.

KENYA PRIVACY LAW REVIEW

Practice Note Series · Data Protection & AI Governance

PRIVACY & DATA PROTECTION

Kenya July 2026 · Practice Note No. 005 (2026)

Privacy by Design

Embedding data protection into systems, products and processes under the Data Protection Act, 2019

Muchangi Patrick | Muchangi Patrick & Associates Advocates
Advocate of the High Court of Kenya · Privacy, Data Protection & AI Governance Specialist IN THIS ARTICLE

1. Introduction & Scope	2. Legal Framework	3. The NHIF Decision	4. PbD in Practice
5. DPIAs as a Design Tool	6. Data Mapping & Audits	7. Implementation Strategy	8. Conclusion

KEY TAKEAWAYS

- Section 41 of the Data Protection Act, 2019 makes privacy by design and by default a binding legal obligation, not a best practice.
- The ODPC's decision in Okwomi v. NHIF shows that a single unverified system field can trigger enforcement liability under Section 41.
- A Data Protection Impact Assessment carried out at the design stage is the clearest evidence an organisation can produce that it took Section 41 seriously.
- Data mapping, technical safeguards, staff training and vendor oversight together form the practical compliance programme this Practice Note recommends.

To cite: Muchangi Patrick, *Privacy by Design: Embedding Data Protection into Systems, Products and Processes under the Data Protection Act, 2019*, Kenya Privacy Law Review, Practice Note No. 005 (July 2026).

1. INTRODUCTION AND SCOPE

1.1 Purpose of this Practice Note

This Practice Note provides comprehensive guidance on the concept of privacy by design and by default under the Data Protection Act, 2019 (the “DPA”). It addresses the statutory obligation of data controllers and processors to embed data protection principles into the design of products, services, and systems from the very beginning, rather than as an afterthought.

Privacy by design is not merely a compliance checkbox; it is a foundational approach to data protection that requires organisations to consider privacy and data protection issues at the design phase of any system, service, product, or process and then throughout its lifecycle. When properly implemented, privacy by design ensures that organisations achieve their objectives in the least privacy-intrusive way possible and that data subjects' rights are protected as a matter of course, not as an afterthought.

“Privacy by design is not a theoretical concept — organisations must implement technical measures that prevent privacy violations from occurring in the first place.”

1.2 The Constitutional Foundation

Article 31 of the Constitution of Kenya, 2010 guarantees the right to privacy as a fundamental human right. The DPA was enacted to give effect to this constitutional protection. The obligation to implement privacy by design arises directly from the DPA and is central to operationalising the constitutional right to privacy.

1.3 Privacy by Design vs. Privacy by Default

The concepts of privacy by design and privacy by default are distinct but complementary:

Privacy by Design requires data controllers and data processors to consider privacy and data protection issues at the design phase of any system, service, product, or process, and then throughout the lifecycle. Privacy principles must be “baked into” data processing and business activities from the outset.

Privacy by Default requires organisations to ensure that, by default, only personal data necessary for each specific purpose is processed. The highest privacy standards apply automatically, and data subjects should not have to take any action to protect their privacy. Where organisations collect personal data, the default setting should be the most privacy-protective option.

2. THE LEGAL FRAMEWORK FOR PRIVACY BY DESIGN

2.1 Section 41 of the Data Protection Act, 2019

Section 41 of the DPA is the primary provision governing privacy by design and by default. It provides:

Section 41(1): Every data controller or data processor shall implement appropriate technical and organisational measures which are designed to implement the data protection principles in an effective manner and to integrate necessary safeguards for that purpose into the processing.

Section 41(2): The data controller or data processor shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which is necessary for each specific purpose is processed, taking into consideration — the amount of personal data collected, the extent of its processing, the period of its storage, its accessibility, the cost of processing data, and the technologies and tools used.

Section 41(3) requires a data controller or data processor to consider the following measures:

1. Identify reasonably foreseeable internal and external risks to personal data under the person's possession or control and establish and maintain appropriate safeguards against the identified risks
2. Ensure pseudonymisation and encryption of personal data
3. Provide for access to personal data in a timely manner in the event of a physical or technical incident
4. Verify that the safeguards are effectively implemented
5. Ensure that the safeguards are continually updated in response to new risks or deficiencies

2.2 The ODPC Strategic Plan 2025–2029

The ODPC's Strategic Plan 2025–2029 explicitly commits to promoting data protection by design or by default as a core principle. The Plan envisions fostering trust and transparency in data protection in Kenya, with data protection by design embedded as a foundational principle across all sectors.

The Plan's focus on privacy by design is further evidenced by the ODPC's collaboration with Konza Technopolis to implement privacy-by-design principles in smart city infrastructure, reflecting a shared vision to ensure that digital transformation in Kenya is built on a foundation of trust, accountability, and respect for data privacy.

3. THE NHIF ODPC DECISION — WHEN SYSTEMS FAIL PRIVACY BY DESIGN

CASE IN FOCUS

Simon Mukabane Okwomi v. National Health Insurance Fund

ODPC Complaint No. 1685 of 2023 [2025] · Office of the Data Protection Commissioner

3.1 Facts

The Complainant discovered that the National Health Insurance Fund (NHIF) had included unknown individuals as beneficiaries under his medical cover without his knowledge or consent. When the Complainant wrote to NHIF demanding the immediate removal of these unknown beneficiaries, NHIF failed to adhere to his request for rectification.

3.2 The Systemic Failure

The ODPC's investigation revealed a more fundamental issue. The inclusion of unknown beneficiaries was not merely a data accuracy problem; it was attributable to NHIF's failure to incorporate, in its ICT systems, a safeguard to confirm data subjects' identities prior to updating their beneficiaries. The result was that unknown beneficiaries could be added to a member's cover inadvertently.

In its response to the complaint, NHIF confirmed that it had not incorporated the necessary validation control to confirm the Complainant's beneficiaries.

3.3 Holdings

The ODPC found that NHIF's systems did not meet the requirements of Section 41 of the DPA. By failing to incorporate identity verification safeguards at the design stage of its ICT systems, NHIF had violated its obligation to implement appropriate technical and organisational measures for data processing. The ODPC found that NHIF did not fulfil its obligations under Section 41 of the DPA.

“A single design flaw can result in multiple data protection breaches — the obligation under Section 41 requires proactive, not reactive, action.”

3.4 Significance

First, privacy by design is not merely a theoretical concept. Organisations must implement technical measures that prevent privacy violations from occurring in the first place.

Second, system design failures can lead to privacy violations that affect numerous data subjects. A single design flaw can result in multiple data protection breaches.

Third, conducting a Data Protection Impact Assessment at the design stage would have helped NHIF identify and mitigate the risk of unauthorised beneficiaries being added to members' covers.

Fourth, the obligation to implement appropriate technical and organisational measures under Section 41 requires proactive, not reactive, action.

3.5 Lessons for Data Handlers

1. Verify identities at the point of data capture: ensure that systems confirm data subjects' identities before making changes to their personal data.
2. Conduct DPIAs at design stage: a DPIA would have identified the risk of unauthorised beneficiary additions and prompted the implementation of safeguards.
3. Regularly audit and update systems: data protection by design requires continuous monitoring and updating of systems in response to new risks or deficiencies.
4. Implement access controls and validation mechanisms: technical safeguards such as two-factor authentication, authorisation workflows, and validation rules should be built into systems.

4. PRIVACY BY DESIGN IN PRACTICE

4.1 The Seven Principles

While the DPA does not expressly codify the seven foundational principles of privacy by design, these principles provide a useful framework for implementation:

1. Proactive not Reactive; Preventative not Remedial — privacy by design is about preventing privacy breaches before they occur, not fixing them after the fact.
2. Privacy as the Default Setting — personal data should be automatically protected in any given IT system or business practice.
3. Privacy Embedded into Design — privacy should be integrated into the design and architecture of IT systems and business practices, not added on.
4. Full Functionality, Positive-Sum not Zero-Sum — privacy by design accommodates all legitimate interests rather than forcing unnecessary trade-offs.
5. End-to-End Security, Full Lifecycle Protection — privacy must be incorporated throughout the entire lifecycle of personal data, from collection to deletion.
6. Visibility and Transparency — all stakeholders should be assured the system operates according to its stated promises and objectives.
7. Respect for User Privacy — the interests of the individual remain paramount, with strong privacy defaults, appropriate notice, and user-friendly options.

4.2 Practical Steps for Organisations

1. Embed privacy considerations at the outset of any system, service, product, or process.
2. Specify personal data required before processing starts, and why it is necessary.
3. Appropriately inform individuals of how their data will be processed before collection begins.
4. Only process necessary personal data — limit processing to what the specific purpose requires.
5. Implement technical measures to limit repurposing of personal data beyond its original collection purpose.

4.3 Data Minimisation and Purpose Limitation

Data minimisation and purpose limitation are core elements of privacy by design. The DPA requires that personal data collected should be adequate, relevant, and limited to what is necessary in relation to the purposes for which it is processed. Organisations should ask themselves:

- Is the collection of this personal data necessary?
- Is the volume of data being collected proportionate?
- Is the personal data being used for purposes other than those for which it was collected?
- Are we storing data longer than necessary?

5. DATA PROTECTION IMPACT ASSESSMENTS AS A DESIGN TOOL

5.1 The DPIA Requirement

Section 31 of the DPA requires data controllers to carry out a Data Protection Impact Assessment (DPIA) before processing that is likely to result in a high risk to the rights and freedoms of data subjects. Regulation 49 of the General Regulations classifies processing operations that present high risks, including:

1. Automated decision-making or profiling with legal or similar effects
2. Large-scale processing for a purpose other than originally intended
3. Processing of biometric or genetic data
4. Changes increasing risk to data subjects
5. Large-scale processing of personal data
6. Use of innovative technology or organisational methods

5.2 What a DPIA Must Address

For a DPIA to meet the minimum requirements of the DPA and its subsidiary legislation, it must address:

- The amount of personal data processed and the extent of processing
- The storage and accessibility of the personal data
- The state of technological development available for processing
- The specific risks attendant to the processing of personal data
- A systematic description of the intended processing operations and their purpose
- The necessity and proportionality of the processing operations
- The risks to the rights and freedoms of data subjects
- The measures envisaged to address the identified risks
- The safeguards implemented to ensure the protection of personal data

5.3 The Worldcoin Decision

In *Republic v. Tools for Humanity Corporation (US) & 8 others*, the High Court emphasised the importance of DPIAs. The Court found that the respondents had not carried out a DPIA prior to processing biometric personal data, in contravention of the DPA. Consequently, the Court prohibited any further processing of biometric personal data without first undertaking a DPIA.

The Court noted that a DPIA is an accountability tool that enables data handlers to identify, assess, and mitigate risks to the rights and freedoms of data subjects during data processing activities. Without a DPIA, organisations cannot demonstrate that they have adequately considered and addressed privacy risks.

“Without a DPIA, organisations cannot demonstrate that they have adequately considered and addressed privacy risks.”

5.4 When to Conduct a DPIA

1. Before processing begins — the DPIA must be completed before the processing commences.
2. Where processing is high-risk — likely to result in a high risk to data subjects' rights and freedoms.
3. When changes are made — where changes to processing operations increase the risk to data subjects.
4. When new technologies are adopted — where innovative technologies are used for processing.

5.5 Submission to ODPC

Where the DPIA indicates that the processing would result in a high risk that cannot be adequately mitigated, the data controller must consult the ODPC before proceeding. Regulation 49 requires data handlers to submit a DPIA report 60 days before processing personal data where the processing is likely to pose a high risk.

6. DATA MAPPING AND SELF-AUDITS

6.1 The Importance of Data Mapping

Data mapping is a foundational activity for implementing privacy by design. The ODPC emphasises that organisations should conduct self-audits to understand what categories of personal data they handle and process, how the personal data is stored, protected, and how such personal data moves in and out of the organisation. Data mapping helps organisations:

1. Identify processing activities — covering collection, recording, organisation, structuring, storage, adaptation, alteration, retrieval, consultation, use, disclosure, dissemination, alignment, combination, restriction, erasure, or destruction of personal data.
2. Assess compliance — self-audits and data mapping determine compliance with the DPA and the nature of personal data handled.
3. Identify risks — by mapping data flows, organisations can identify risks to personal data and implement appropriate safeguards.

6.2 The Audit Process

Organisations should undertake internal audits and data mapping to understand:

- What personal data is held — identify all categories of personal data processed.
- Why it is processed — determine the purposes for which personal data is processed.
- How it is processed — identify collection, storage, use, and disclosure operations.
- Who processes it — identify all data controllers, data processors, and third parties involved.
- Where it is processed — identify locations, including any cross-border transfers.
- How long it is retained — identify retention periods and ensure timely deletion.

6.3 Integrating Data Mapping into Design

Data mapping should be integrated into the design process for any system, service, product, or process that will process personal data. By understanding the data flows from the outset, organisations can design systems that minimise data collection, restrict access, and ensure compliance with the DPA's principles.

7. PRACTICAL IMPLEMENTATION STRATEGIES

7.1 Develop a Privacy by Design Policy

Organisations should develop a comprehensive policy on privacy by design that addresses:

- Governance — who is responsible for implementing privacy by design?
- Process — how will privacy considerations be integrated into design processes?
- Standards — what are the minimum privacy standards that must be met?
- Audit — how will compliance be monitored and verified?
- Review — how will policies be updated in response to new risks?

7.2 Appoint a Data Protection Officer

Section 24 of the DPA requires organisations to appoint a Data Protection Officer where they are a data controller or processor. The DPO plays a critical role in implementing privacy by design by advising on data processing requirements, ensuring compliance with the DPA, facilitating capacity building of staff, providing advice on DPIAs, and cooperating with the Data Commissioner.

7.3 Implement Appropriate Technical and Organisational Measures

Section 41 of the DPA requires organisations to implement appropriate technical and organisational measures including:

1. Identifying foreseeable risks — identify reasonably foreseeable internal and external risks to personal data.
2. Establishing safeguards — establish and maintain appropriate safeguards against identified risks.
3. Pseudonymisation and encryption — ensure pseudonymisation and encryption of personal data.
4. Timely access — provide for access to personal data in a timely manner in the event of a physical or technical incident.
5. Verification — verify that safeguards are effectively implemented.
6. Continuous updating — ensure that safeguards are continually updated in response to new risks or deficiencies.

7.4 Conduct DPIAs

Organisations should conduct DPIAs where processing is likely to result in a high risk to data subjects' rights and freedoms. DPIAs should be conducted before processing begins and should be reviewed periodically.

7.5 Data Minimisation

Organisations should collect only the personal data necessary for their purposes. Section 41(2) requires organisations to ensure that, by default, only personal data which is necessary for each specific purpose is processed.

7.6 Staff Training

Privacy by design requires a cultural shift within organisations. Staff at all levels must understand the importance of data protection and the practical steps they can take to implement privacy by design. Organisations should:

- Provide regular training to all staff on data protection principles and requirements.
- Create awareness of the importance of privacy by design.
- Embed a privacy-centric culture where data protection is everyone's responsibility.

7.7 Vendor Management

Privacy by design extends to third-party vendors. Organisations must ensure that vendors who process personal data on their behalf implement appropriate privacy by design measures.

8. CONCLUSION

Privacy by design is a foundational principle of Kenya's data protection framework. Section 41 of the DPA requires organisations to embed data protection into the design of systems, products, and processes from the outset. The ODPC has emphasised the importance of privacy by design, and enforcement actions such as the NHIF decision demonstrate that the ODPC will hold organisations accountable for failing to implement appropriate technical and organisational measures.

Data handlers must adopt a proactive approach to privacy by design, integrating data protection principles into all stages of their operations. DPIAs, data mapping, self-audits, and the implementation of technical and organisational measures are essential tools for achieving compliance.

The NHIF decision serves as a powerful reminder that privacy by design is not merely a theoretical obligation. Organisations that fail to embed privacy into their systems expose themselves to enforcement action and risk violating the rights of data subjects. In an era of rapid digital transformation, privacy by design is not optional — it is a legal requirement and a business imperative.

SUMMARY TABLE

Legal Basis	Section 41 of the DPA requires privacy by design and by default
NHIF Decision	Failure to incorporate identity verification at design stage violates Section 41
DPIA as Design Tool	DPIAs help identify and mitigate risks at the design stage
Data Minimisation	Only collect personal data necessary for the specific purpose
Technical Measures	Encryption, pseudonymisation, and validation controls are essential
Organisational Measures	Policies, training, and governance structures are required
Vendor Management	Ensure third parties implement privacy by design

Disclaimer: This Practice Note is for guidance purposes only and does not constitute legal advice. Organisations should seek independent legal advice on specific compliance matters.

ABOUT THE AUTHOR

	Muchangi Patrick <i>Advocate of the High Court of Kenya · Founder, Muchangi Patrick & Associates Advocates</i> Muchangi Patrick advises boards, regulators and technology companies on data protection, AI governance and fintech law, and edits the Kenya Privacy Law Review.
---	---

KENYA PRIVACY LAW REVIEW

A professional publication series providing authoritative guidance on privacy, data protection, and AI governance in Kenya, published by Muchangi Patrick & Associates Advocates. For inquiries, please contact the author.

Data Protection	Privacy by Design	Section 41 DPA	ODPC	AI Governance	Kenya
-----------------	-------------------	----------------	------	---------------	-------